

TECHSECURE S.A. — PROGRAMA DE CIBERSEGURANÇA

ATLAS DE AMEAÇAS CIBERNÉTICAS

DOCUMENTAÇÃO TÉCNICA DE AMEAÇAS

Análise Comparativa: Bomba Lógica (Logic Bomb) × Bomba Relógio (Time Bomb)

Organização:	TechSecure S.A. — Cyber Threat Intelligence
Autores / Especialistas:	Victor Lemos Barbosa & Kaique dos Santos Silva
Temas Mapeados:	Ameaça 1: Bomba Lógica Ameaça 2: Bomba Relógio
Comparação Central:	Condição Lógica (Mudança de Estado) × Gatilho Temporal (Relógio / Cron)

1. Contextualização e Objetivo do Projeto

A organização fictícia TechSecure S.A. está estruturando seu programa interno de conscientização e resposta a incidentes de segurança da informação. Como parte do Atlas de Ameaças Cibernéticas da turma, esta documentação técnica desenvolvida por Victor Lemos Barbosa e Kaique dos Santos Silva aborda de maneira aprofundada duas ameaças críticas associadas a códigos ocultos e destruição de dados: a Bomba Lógica (Logic Bomb) e a Bomba Relógio (Time Bomb).

O objetivo central deste documento é capacitar analistas de segurança, administradores de sistemas e equipes de resposta a incidentes a compreenderem a arquitetura de funcionamento, os vetores de infecção, as técnicas de evasão, os impactos operacionais e os procedimentos adequados de detecção, prevenção e contenção fundamentados nesses mecanismos maliciosos.

Diretriz Estratégica — TechSecure S.A.:

A prevenção contra ameaças com gatilhos ocultos exige uma abordagem multifacetada que combina controle rigoroso de acessos privilegiados (PoLP), monitoramento contínuo de integridade de arquivos (FIM) e processos estruturados de desligamento de colaboradores.

2. Ameaça 1: Bomba Lógica (Logic Bomb / Slag Code)

2.1 Conceito e Definições Oficiais

De acordo com a definição oficial do glossário do NIST CSRC e do documento CNSSI 4009 / NIST SP 800-12 Rev. 1, uma bomba lógica é definida como: *"Uma peça de código inserida intencionalmente em um software que disparará uma função maliciosa quando condições especificadas forem atendidas"*.

No meio técnico e acadêmico, a bomba lógica também é conhecida pelo termo **slag code** (conforme documentado pelo SANS Institute / GIAC). Ela se caracteriza por ser um conjunto de instruções dormentes acopladas a softwares, scripts de infraestrutura ou utilitários legítimos. Diferente de vírus e worms convencionais, a bomba lógica tradicional **não possui capacidade intrínseca de autorreplicação** e não abre portas de fundo (backdoors) de forma autônoma; sua execução depende estritamente do atendimento de sua condição lógica de disparo.

2.2 Histórico, Origem e Evolução

A origem histórica da bomba lógica está estreitamente vinculada ao problema da **Ameaça Interna (Insider Threat)**. Pesquisas e levantamentos do SANS Institute apontam que colaboradores e administradores de sistemas com acesso privilegiado figuram entre as maiores fontes de risco organizacional. Nas décadas de 1980 e 1990, alguns desenvolvedores de software comercial inseriam rotinas lógicas que desativavam ou destruíam a aplicação caso a licença de uso não fosse renovada — prática hoje considerada ilícita. Na segurança corporativa moderna, bombas lógicas são frequentemente implantadas por colaboradores insatisfeitos com demissões, reestruturações ou bonificações negadas.

2.3 Funcionamento Técnico e Condições de Estado

O funcionamento de uma bomba lógica divide-se em duas etapas essenciais: o **Gatilho (Triggering)** e a **Carga Útil (Payload)**. Dentre as condições de estado mais comuns, destacam-se:

- **Gatilhos por Mudança de Estado (State Changing):** Consultam variáveis do sistema operacional, como a permanência do registro do funcionário no banco de dados do RH, modificação de chaves no registro ou exclusão de arquivos específicos.
- **Mecanismo Dead Man's Switch:** Exige a inserção periódica de um sinal de confirmação ou senha por parte do administrador. Caso o responsável seja demitido e o sinal interrompido, a ausência da ação humana ativa o payload destrutivo.
- **Eventos e Ações do Usuário:** Captura de combinações específicas de teclas via keyloggers ou execução de rotinas específicas na aplicação da empresa.

2.4 Vetores de Comprometimento e Destruição de Dados (MITRE ATT&CK; T1485)

A bomba lógica costuma ser implantada diretamente por indivíduos com credenciais elevadas, escrita em scripts (Bash, PowerShell, Python, Perl) ou incorporada ao código-fonte compilado. O impacto primário está categorizado no framework **MITRE ATT&CK; sob a técnica T1485 (Data Destruction)**. Enquanto comandos convencionais do sistema operacional (como `del` no Windows ou `rm` no Linux) removem apenas ponteiros do sistema de arquivos mantendo os dados recuperáveis via perícia forense, a carga destrutiva de uma bomba lógica efetua a **sobrescrita de arquivos com dados aleatórios ou nulos**, corrompe partições e volumes, inviabilizando qualquer recuperação.

2.5 Indicadores, Prevenção e Resposta SANS

A detecção envolve o monitoramento de utilitários de limpeza/sobrescrita (como `cipher /w`, `SDelete`, `shred`, `dd` - estratégias DET0146/AN0411 do MITRE ATT&CK). A metodologia do SANS Institute define 6 etapas para a difusão e neutralização de uma bomba lógica:

- **1. Isolamento (Evacuate the Area):** Desconectar o host afetado da rede imediatamente para conter a destruição.
- **2. Preservação de Evidências:** Coletar imagem forense da memória RAM e do disco antes de reiniciar ou alterar o sistema.
- **3. Restauração do Ambiente:** Reinstalar o sistema operacional a partir de mídias limpas de produção.
- **4. Verificação de Backups:** Auditar rigorosamente as cópias de segurança para evitar que o código dormente seja restaurado.
- **5. Desativação em Laboratório:** Analisar a amostra em ambiente sandbox isolado, testando manipulação de variáveis de estado.
- **6. Restauração Controlada:** Homologar e reconectar o serviço à rede sob monitoramento contínuo.

3. Ameaça 2: Bomba Relógio (Time Bomb)

3.1 Conceito e Mecanismos de Disparo

A Bomba Relógio (Time Bomb) é uma **subcategoria específica da bomba lógica** cujo gatilho depende estritamente da dimensão temporal. Conforme documentado pelo SANS Institute, a Time Bomb utiliza três mecanismos principais de temporalidade:

- **Data/Hora Específica (System Clock):** Compara a hora do relógio interno do SO (ex: `time()`, `GetSystemTime()`) com a data de detonação pré-programada.
- **Contagem Regressiva (Countdown Timer):** Implementa um contador próprio baseado no número de segundos decorridos desde a instalação, sendo imune a alterações simples no relógio do SO.
- **Abuso de Agendadores Nativos:** Utiliza utilitários legítimos do sistema como Cron (Linux) ou Windows Task Scheduler para disparar rotinas destrutivas em horários de baixa vigilância.

3.2 Evasão e Estratégias de Defesa

Para burlar a análise automatizada em sandboxes, a Time Bomb permanece inativa se a data do teste for anterior à data programada. As defesas incluem auditorias contínuas de agendadores de tarefas, simulações de avanço temporal no relógio em sandbox e proteção offline de backups (MITRE Mitigation M1053).

4. Comparação Direta entre as Ameaças

A tabela a seguir estabelece o confronto direto entre a Bomba Lógica (Estado) e a Bomba Relógio (Tempo) com base nos critérios essenciais de Ciência da Computação e Segurança da Informação:

Critério de Análise	Bomba Lógica (Logic Bomb)	Bomba Relógio (Time Bomb)
Gatilho Principal (Trigger)	Mudança de estado do sistema, banco de dados (RH), ausência de ação (Dead Man's Switch).	Data, hora fixa do sistema, contagem regressiva de tempo ou agendadores.
Dependência do Relógio (Clock)	Nenhuma ou secundária. Baseia-se em verificações lógicas de software.	Total. Consulta o relógio interno (System Clock) ou contador próprio.
Agendadores Nativos	Raramente exposta em agendadores; embutida na lógica de código da aplicação.	Frequente. Abusa de utilitários como Cron (Linux) e Task Scheduler (Windows).
Evasão em Sandbox	Inatividade até que a condição de estado (ex: banco de dados RH) se altere.	Inatividade até atingir a data/hora programada de detonação.
Análise / Neutralização	Engenharia reversa de código, SAST e monitoramento de integridade de arquivos (FIM).	Avanço artificial do relógio do sistema em sandbox isolada e auditoria de tarefas.
Risco na Restauração	Reativa se o estado modificado (ex: conta deletada) continuar no backup.	Disparo imediato se a data do sistema for posterior à da bomba.

5. Estudos de Caso Reais (Registros do U.S. Department of Justice)

5.1 Caso 1: UBS PaineWebber — Roger Duronio (2002)

Roger Duronio, administrador de sistemas da UBS PaineWebber em Weehawken (New Jersey), construiu uma bomba lógica motivado por insatisfação salarial. Entre novembro de 2001 e fevereiro de 2002, ele implantou o código malicioso em aproximadamente 1.000 dos 1.500 computadores em rede nas filiais da empresa. Ele pediu demissão em 22 de fevereiro de 2002. Em 4 de março de 2002, a bomba lógica ativou-se e iniciou a destruição de arquivos cruciais. Visando lucrar com o ataque, Duronio investiu US\$ 21.762 na compra de 318 contratos de opções de venda (put options) das ações da UBS A.G., antecipando uma queda no mercado. O prejuízo em reparos ultrapassou US\$ 3 milhões, resultando em sua condenação por fraude de valores mobiliários e fraude de computador (processo indiciado pelo U.S. DOJ).

5.2 Caso 2: Fannie Mae — Rajendrasinh Makwana (2008)

Rajendrasinh Babubhai Makwana, engenheiro UNIX terceirizado na Fannie Mae em Urbana (Maryland), foi demitido em 24 de outubro de 2008. Antes de entregar seu laptop, transmitiu um script malicioso para os servidores da empresa com um gatilho temporal configurado para 31 de janeiro de 2009. O código visava se propagar por cerca de 5.000 servidores e apagar todos os dados financeiros e operacionais de hipotecas. Em 29 de outubro de 2008, um engenheiro sênior descobriu o script oculto em uma rotina diária. Makwana foi julgado e condenado por intrusão de computadores em 2010 pelo júri federal de Maryland.

6. Conclusões, Desafio do Analista e Referências

A análise técnica desenvolvida por Victor Lemos Barbosa e Kaique dos Santos Silva evidencia que a defesa cibernética contra ameaças ocultas deve focar na gestão estrita de privilégios (PoLP), monitoramento de integridade de arquivos (FIM) e auditorias de agendadores de tarefas.

Desafio do Analista (Cenário Interativo para a Turma):

Na madrugada de domingo, exatamente às 02:00, os servidores de banco de dados da TechSecure S.A. pararam de responder devido à deleção maciça de tabelas operacionais. Nenhum colaborador realizou login no momento do incidente.

• **Pergunta:** Qual ameaça explica melhor este incidente?

• **Resposta Fundamentada:** Trata-se de uma Bomba Relógio (Time Bomb). O disparo ocorreu de forma assíncrona baseado no System Clock ou em uma tarefa agendada prévia (Cron/Task Scheduler), sem depender de ação de usuário no momento da detonação.

7. Referências Bibliográficas

- 1. NIST CSRC. Glossary: Logic Bomb. National Institute of Standards and Technology. Disponível em: <https://csrc.nist.gov/glossary/term/logic_bomb>.
- 2. NIST. Glossary of Key Information Security Terms, NISTIR 7298 Rev. 2 / CNSSI 4009. U.S. Department of Commerce, 2013.
- 3. MITRE ATT&CK.; Technique T1485: Data Destruction. Disponível em: <<https://attack.mitre.org/techniques/T1485/>>.
- 4. SANS Institute / GIAC. ROBILLARD, Nicolas. Diffusing the Logic Bomb. GIAC Security Essentials Certification (GSEC), 2004.
- 5. U.S. Department of Justice (DOJ). Disgruntled UBS PaineWebber Employee Charged with Allegedly Unleashing 'Logic Bomb' on Company Computers. Press Release, District of New Jersey, 2002.
- 6. U.S. Department of Justice (DOJ). Former Employee of Fannie Mae Contractor Convicted Of Attempting to Destroy Fannie Mae Computer Data. Press Release, District of Maryland, 2010.
- 7. CIBERSEGURANÇA. Situação de Aprendizagem: Ameaças Cibernéticas — Atlas de Ameaças Cibernéticas. Documento de Requisitos da Unidade Curricular, TechSecure S.A.